

Department of Defense Vulnerability Disclosure Policy (VDP) Analysis Report

Daniel Stewart - IT-157 Spring 2026

Introduction

The Department of Defense (DoD) Vulnerability Disclosure Program (VDP) provides a legal and structured process for security researchers to report vulnerabilities found in publicly accessible DoD systems. The program improves cybersecurity while providing researchers with a safe method to disclose vulnerabilities when acting in good faith. The policy establishes rules regarding authorized testing, prohibited activities, and evaluation of submitted findings.

Safe Harbor and Researcher Protection

One of the most important parts of the DoD VDP is its Safe Harbor commitment. Researchers who follow the published rules, remain within scope, avoid prohibited activities, and responsibly report vulnerabilities are generally protected from legal action by the DoD. Safe Harbor distinguishes ethical security research from criminal hacking and encourages responsible vulnerability disclosure.

Out-of-Scope Activities ('Kill Switch')

The DoD policy identifies activities that are prohibited during testing. Examples include denial-of-service (DoS) attacks, distributed denial-of-service (DDoS) attacks, social engineering attacks against DoD personnel, and attempts to gain physical access to facilities or equipment. These restrictions establish clear boundaries that researchers must follow to maintain Safe Harbor protections.

Valid, Duplicate, and Informational Findings

A Valid finding is a previously unknown vulnerability that can be reproduced and presents a legitimate security risk to an in-scope system. A Duplicate finding is a vulnerability that has already been reported by another researcher. An Informational finding describes behavior that does not represent a meaningful security vulnerability or presents little security impact. These classifications help the DoD prioritize remediation efforts.

Conclusion

The Department of Defense Vulnerability Disclosure Program demonstrates how organizations can collaborate with the cybersecurity community while maintaining legal and operational safeguards. Safe Harbor protections, clearly defined testing boundaries, and structured vulnerability evaluation processes help researchers act responsibly and legally. Understanding these policies is essential for cybersecurity professionals because authorization and compliance are just as important as technical skills.